

Universidad Tecnológica de Querétaro

Ingeniería en Desarrollo y Gestión de Software

Materia: Desarrollo para Dispositivos Inteligentes

**Evaluación 2: Ecosistema Completo (Teléfono +
Wearable + Smart TV)**

Documento: Documentación de Seguridad

Alumno: Mauricio Gabriel Vazquez

Matrícula: 2023371007

Proyecto: TravelApp - Kiosco Inteligente de Abordaje

Agosto 2026

Índice

1. Validación de Orígenes de Comunicación	2
2. Aviso de Privacidad (Apegado a la LFPDPPP)	2
2.1. Responsable del Tratamiento de Datos	2
2.2. Datos Personales Recabados	2
2.3. Finalidad del Tratamiento	2
2.4. Derechos ARCO	3
3. Plan de Retención y Ciclo de Vida de Datos	3
4. Checklist de Seguridad PWA	3

1. Validación de Orígenes de Comunicación

En el ecosistema de TravelApp, la comunicación en tiempo real entre la PWA (Smart TV), la aplicación móvil y el Wearable se realiza a través de WebSockets (Socket.io) respaldados por un servidor en Node.js.

Para garantizar la seguridad y evitar ataques de Cross-Origin Resource Sharing (CORS) o inyección de mensajes desde fuentes no autorizadas, se implementó una estricta validación de origen (origin validation) en la configuración del servidor, reemplazando la validación tradicional de `BroadcastChannel`:

- **Lista Blanca de Orígenes (CORS):** El servidor rechaza cualquier conexión HTTP o de WebSocket que no provenga de las direcciones IP locales autorizadas (`http://localhost:4200`, `http://127.0.0.1:5500`) o del dominio de producción.
- **Aislamiento de Salas (Rooms):** Los mensajes de telemetría y las órdenes de abordaje se transmiten en "salas" privadas identificadas por el `userId` único (ej. `tv_userId`). Un dispositivo no puede escuchar ni enviar eventos a la sesión de otro pasajero.

2. Aviso de Privacidad (Apegado a la LFPDPPP)

Con fundamento en los artículos 8, 15, 16, 33 y 36 de la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP), se emite el presente aviso:

2.1. Responsable del Tratamiento de Datos

El responsable del uso y protección de sus datos personales es Mauricio Gabriel Vazquez, titular y desarrollador del proyecto académico TravelApp.

2.2. Datos Personales Recabados

Para llevar a cabo las finalidades descritas en este ecosistema, utilizaremos los siguientes datos:

- **Datos de Identificación:** Correo electrónico (utilizado para la sincronización de sesión entre dispositivos).
- **Datos Biométricos y de Salud (Simulados):** Ritmo cardíaco, estimación de calorías quemadas y distancia recorrida (pasos). *Nota: Estos datos son generados localmente mediante simulación BLE para fines estrictamente académicos.*

Base legal: Los datos se procesan bajo el consentimiento explícito del usuario al vincular el dispositivo Wearable con su teléfono móvil.

2.3. Finalidad del Tratamiento

Los datos personales recabados serán utilizados exclusiva y estrictamente para la visualización en tiempo real de los signos vitales del usuario durante el proceso de "abordaje" proyectado en el ecosistema (Smart TV y App Móvil).

2.4. Derechos ARCO

Usted tiene derecho a conocer qué datos personales tenemos, para qué los utilizamos y las condiciones de uso que les damos (Acceso). Asimismo, es su derecho solicitar la corrección de su información en caso de que esté desactualizada (Rectificación); que la eliminemos de nuestros registros o bases de datos (Cancelación); así como oponerse al uso de sus datos personales para fines específicos (Oposición). Para el ejercicio de cualquiera de los derechos ARCO, puede emitir una solicitud desde la configuración de su cuenta en la aplicación móvil.

3. Plan de Retención y Ciclo de Vida de Datos

Para garantizar la privacidad del pasajero y la minimización de almacenamiento, TravelApp implementa el siguiente ciclo de vida sobre la información sensible:

- **Datos Temporales (Telemetría):** El ritmo cardíaco, distancia y tiempo de llegada NO se persisten en ninguna base de datos permanente. Residen en la memoria RAM del servidor (`currentWearableData`) y se sobrescriben instantáneamente al desconectar el wearable o al cancelar el abordaje.
- **Datos Locales (Caché y Sesión):** El identificador de usuario (`tv_userId`) almacenado en el `localStorage` de la Smart TV contiene una estampa de tiempo (`timestamp`).
- **Política de Eliminación (30 Días):** El sistema cuenta con una función de recolección de basura que se ejecuta automáticamente al iniciar la PWA. Esta rutina verifica los *timestamps* locales y elimina definitivamente cualquier registro que supere los 30 días de antigüedad sin intervención manual del usuario.

4. Checklist de Seguridad PWA

La PWA de la Smart TV ha sido blindada cumpliendo con las mejores prácticas de seguridad web:

- ✓ **Content Security Policy (CSP):** Se implementó una etiqueta `<meta>` restrictiva en el `index.html` definiendo directivas explícitas (`default-src`, `connect-src`, `media-src`, `script-src`) limitando la ejecución a 'self' y a los orígenes del servidor Node.js y la CDN de Socket.io.
- ✓ **HTTPS en Producción:** El entorno de producción exige encriptación TLS (HTTPS) para el registro de Service Workers y la protección de carga útil de datos.
- ✓ **Validación de Origen:** (Cubierto en la Sección 1).
- ✓ **Seguridad en Modo Offline:** Las respuestas cacheadas en el `sw.js` no almacenan peticiones vulnerables (POST para inicio de sesión), utilizando una estrategia *Cache First* exclusivamente para archivos estáticos no sensibles.